PYC

exec

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Com base na análise detalhada do código-fonte e da estrutura contida no arquivo anexo, apresento a seguir o passo a passo da avaliação técnica e, por fim, a conclusão sobre a sua natureza.

Análise Passo a Passo

1. Módulo de Varredura e Reconhecimento (`run_scan.sh` e `masscan`)

O que faz: O script de orquestração (`run_scan.sh`) automatiza a execução da ferramenta `masscan` para varrer faixas de IPs à procura de portas abertas específicas, focando primordialmente nas portas **22 (SSH)** e **5522**.

Evidência: O código verifica dependências, instala ferramentas do sistema se necessário e executa varreduras em segundo plano (`screen`), extraindo pares de `ip:port` válidos.

2. Módulo de Ataque por Força Bruta / Credenciais Embutidas (`ssh_scanner.py`)

O que faz: Utiliza a biblioteca Python `paramiko` para realizar conexões SSH automatizadas e multi-thread em larga escala nos alvos descobertos.

Evidência: O script testa senhas predefinidas e duras no código (hardcoded), como `"LeitboGi0ro"` e `"123@@@"` , com o objetivo de obter acesso administrativo não autorizado a servidores expostos na internet.

3. Módulo de Auto-Propagação e C&C (`bendi.py` / Monitor)

O que faz: O script atua como um mecanismo de infecção lateral (worm). Assim que um servidor é comprometido via força bruta SSH, o script realiza as seguintes ações:

Upload de payload: Copia a si mesmo (`bendi.py`) para o diretório `/tmp/` do servidor remoto.

Instalação de dependências: Verifica e instala automaticamente o `python3` e bibliotecas necessárias no alvo remoto.

Execução remota: Executa o script clonado para transformar o novo servidor em um novo nó de varredura.

Comunicação com C&C: Registra os IPs recém-infectados em uma API central externa (`[https://sou.pp.ua/add_ip.php](https://sou.pp.ua/add_ip.php)`) para evitar duplicação de esforço.

4. Persistência no Sistema e Exfiltração (`systemd` e Telegram)

O que faz:

Persistência: Cria serviços ocultos no gerenciador do sistema (`systemd`), registrando tarefas como `scan-runner.service` e `file-monitor.service` em diretórios do sistema como `/usr/lib/.sysd-scan/` e `/usr/lib/.sysd-monitor/` , garantindo que o invasor mantenha controle após reinicializações.

Notificação via Bot: Utiliza tokens de API e Chat IDs do **Telegram** (`TELEGRAM_BOT_TOKEN` , `TELEGRAM_CHAT_ID`) para enviar relatórios de infecção e status de servidores comprometidos diretamente ao operador mal-intencionado.

Conclusão

Este arquivo é um MALWARE.

Trata-se de um **Worm / Botnet auto-propagável** projetado para escanear a internet, realizar ataques de força bruta em serviços SSH usando credenciais padrão/fracas, infectar novos hosts Linux, estabelecer persistência oculta via serviços `systemd` , reportar status a um painel de comando e controle (C&C) centralizado e notificar o operador via Telegram.

Qual é a categoria principal deste malware?

A categoria principal deste malware é um **Worm (Verme informático) auto-propagável** com capacidades de **Botnet** e **Scanner de Força Bruta**.

Pode ser decomposto nas seguintes subcategorias funcionais devido ao seu comportamento:

Worm de Auto-Propagação: O script (`bendi.py`) tem a capacidade de detetar novos sistemas vulneráveis, autenticar-se neles, copiar-se a si próprio (`/tmp/bendi.py`) e executar-se de forma autónoma para infetar novos nós na rede.

Malware de Força Bruta e Invasão SSH: Utiliza ferramentas como o `masscan` para detetar portas abertas e o `paramiko` em Python para realizar ataques de força bruta em massa contra o serviço SSH utilizando credenciais predefinidas.

Agente de Botnet / Comando e Controlo (C&C): Regista os servidores comprometidos numa API centralizada (`sou.pp.ua`) e utiliza a aplicação Telegram (através de bot tokens) para reportar o sucesso das invasões e manter controlo remoto sobre a infraestrutura infetada.